

信息安全管理制度

文件编号：POL-SEC-001 版本：V2.1 生效日期：2026 年 7 月 1 日

文件属性	内容
适用范围	全体员工、承包商、供应商驻场人员及访问公司信息系统的第三方
归口部门	信息安全与风险管理部
审批人	首席运营官
保密级别	内部公开
复审周期	每 12 个月一次，或在法规及业务发生重大变化时提前复审

文档说明

本制度规定账号、终端、数据、远程访问、事件报告和第三方接入要求。所有人员应遵循最小权限、职责分离和默认拒绝原则。

本文件为企业制度类 RAG 测试样本文档。公司名称、人员、金额及流程均为虚构，但条款结构、审批逻辑和例外规则按照真实企业制度的写法设计。

2. 身份与访问控制

2.1 账号管理

所有用户必须使用实名账号，禁止共享口令。新员工账号由人力资源系统触发创建，默认有效期与劳动关系一致。离职账号应在离职生效后 30 分钟内停用；高风险离职应在面谈开始前停用。

2.2 多因素认证

- 互联网暴露系统、VPN、云管理控制台和特权账号必须启用 MFA。
- 短信验证码仅作为过渡方式，优先使用硬件密钥或认证器。
- 服务账号不得使用交互式登录，密钥至少每 90 天轮换。
- 紧急账号应封存并在每次使用后 24 小时内复核。

2.3 权限复核

系统负责人每季度复核普通权限，每月复核管理员权限。连续 60 天未使用的高权限应自动暂停，确认仍有业务需要后方可恢复。

账号类型	认证要求	复核周期
普通员工	口令+条件访问	每季度
远程访问	强制 MFA	每季度
管理员	MFA+专用终端	每月
服务账号	密钥/证书	每 90 天轮换

3. 终端与网络安全

3.1 公司终端

公司终端必须安装受管 EDR、磁盘加密和补丁管理代理。用户不得停用安全软件，不得使用越狱或 Root 设备处理公司数据。关键安全补丁应在 7 天内完成，一般高危补丁应在 14 天内完成。

3.2 可移动介质

默认禁止使用 USB 存储设备。确有业务需要时，应申请加密介质并设置最长 30 天的授权。涉密、客户受限或源代码数据不得复制到可移动介质。

3.3 网络访问

- 办公网络与访客网络必须逻辑隔离。
- 未经批准不得搭建无线热点、代理、隧道或远程控制服务。
- 生产环境管理流量必须经过堡垒机或受控管理平面。
- 扫描、抓包和渗透测试须取得系统负责人及安全团队书面授权。

4. 数据分类与处理

4.1 分类级别

数据分为公开、内部、机密和严格机密四级。数据所有者负责确定分类；若无法确认，应暂按机密数据处理。分类标签应体现在文件页眉、存储位置或系统元数据中。

4.2 传输与存储

- 内部数据可存储于公司批准的协作平台。
- 机密数据在传输和静态存储时必须加密。
- 严格机密数据不得上传至个人网盘、公开生成式 AI 或未经批准的 SaaS。
- 包含个人信息的数据跨境传输前必须完成隐私与法律评估。

4.3 保留与销毁

业务记录按照法务发布的保留计划保存。超过保留期限且不存在诉讼保全要求的数据应安全删除；纸质机密文件应使用符合 DIN 66399 P-4 或更高等级的设备销毁。

级别	示例	最低保护要求
公开	官网新闻稿	完整性保护
内部	内部通讯录	受控共享
机密	客户合同、报价	加密+最小权限
严格机密	密钥、并购资料	隔离存储+双人审批

5. 安全事件响应

5.1 报告时限

发现账号被盗、恶意软件、数据误发、设备丢失或异常外联时，应立即停止高风险操作，并在 15 分钟内通过安全热线或事件门户报告。员工不得自行删除日志或对外披露事件。

5.2 分级

- 一级：可能造成大范围业务中断、重大数据泄露或人身风险，15 分钟内启动应急指挥。
- 二级：影响单个关键系统或涉及机密数据，30 分钟内由安全团队牵头。
- 三级：局部影响且无敏感数据暴露，4 小时内完成初步处置。
- 四级：低风险告警或政策偏差，纳入日常工单。

5.3 证据保护

未经授权不得关机、格式化或重装疑似受感染设备。应记录发现时间、现象、已执行操作和相关人员。安全团队负责镜像、日志保全和取证链记录。

级别	典型影响	响应目标
一级	重大中断/重大泄露	15 分钟
二级	关键系统或机密数据	30 分钟
三级	局部业务影响	4 小时
四级	低风险偏差	1 个工作日

6. 第三方、例外与问责

6.1 第三方接入

供应商接入应有明确业务负责人、限定系统范围和到期时间。远程维护必须使用公司批准的 VPN 和 MFA，默认最长授权 90 天；每次高权限操作应留存会话审计。

6.2 政策例外

无法满足控制要求时，申请人须记录业务理由、风险、补偿措施和结束日期。例外最长有效期 180 天，不自动续期。涉及严格机密数据的例外须由 CISO 批准。

6.3 违规处理

故意绕过控制、隐瞒事件、共享特权账号或未经许可外传数据可导致访问权限暂停、纪律处分或合同终止。善意报告错误不会因报告行为本身受到处罚。

6.4 联系方式

安全事件热线：400-800-7711（7×24 小时）；一般咨询：security@example.test。紧急事件应先电话报告，不应仅发送邮件。

版本	日期	主要变化
V2.0	2025-09-01	统一数据分类
V2.1	2026-07-01	缩短事件报告时限